Лекция 01
Введение в курс

ML как часть безопасности системы

ML как компонент

ML – это не отдельная магия, а компонент системы защиты.

Управление риском

Поэтому главное: ошибки неизбежны – риском нужно управлять.

Надежные решения

Итог курса: решения, которым можно доверять в реальной эксплуатации.

Последствия системы

У системы есть последствия: блокировки, тревоги, пропуски.

Понимание ошибок

Мы будем учиться: понимать, где модель ошибается и почему.

Машинное обучение в ИБ – это про решения на данных

Принятие решений

ML принимает решения по наблюдениям, когда правил нет.

Анализ следов

ML анализирует следы: текст письма, признаки поведения, события.

Большой объём

ML полезен там, где объём большой и руками перечислить невозможно.

Один модуль

ML не заменяет безопасность целиком: это один модуль.

Ограничение данных

ML работает только в рамках данных, на которых его учили.

Главный вопрос

Главный вопрос курса: как сделать решение полезным и управляемым.

Если нет данных – нет ML-решения. Если данные плохие – решение будет плохим, даже при идеальном коде.

Ошибки неизбежны, поэтому важен контроль риска

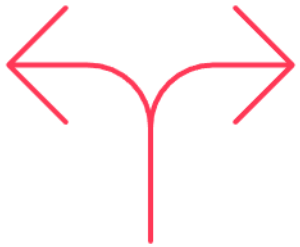
*В безопасности **ошибка модели – не баг**, а ожидаемое свойство реального мира*

Цена ошибки

У любой ошибки есть цена: время людей, простои, недоверие, ущерб.

Неизвестные ошибки

Опасно не то, что модель ошиблась, а то, что мы не знали, как именно она ошибается.



Типы провалов

Два типа провала: мешает работать или пропускает важное.

Управляемый ML

Поэтому мы делаем ML не «максимально умным», а управляемым и проверяемым.

Инженерная цель

Инженерная цель: ошибки становятся прогнозируемыми, последствия – ограниченными.

Модель – это правило, которое превращает признаки в решение

Формализованное правило

Модель – это формализованное правило: как из наблюдений получить решение.

Решение на выходе

На выходе – решение (например, "подозрительно/не подозрительно") и иногда степень уверенности.

Статистические закономерности

Модель не знает смысла событий сама по себе: она знает статистические закономерности из примеров.

Границы модели

У любой модели есть границы: она хорошо работает в пределах похожих ситуаций, а вне их начинает ошибаться.

Признаки на входе

На входе не «реальность», а признаки: измеримые следы и их описания.

Поведение ошибок

Одну и ту же задачу можно решать разными моделями: важно не «название алгоритма», а поведение ошибок.

Плохие признаки

Если признаки плохие – даже лучшая модель будет принимать плохие решения.

Обучение – это настройка правила по примерам из прошлого

Обучение – это процесс

Подбираем параметры правила так, чтобы оно работало на примерах.

Данные задают обучение

Данные задают, чему именно научится модель.

Проверка модели

После обучения мы обязаны проверить модель на новых примерах, которые она не видела.

Ритуал разделения примеров

Поэтому важен ритуал: разделяем примеры, обучаемся на одних, проверяемся на других.

Примеры входов и ответов

Нам нужны примеры входов (признаки) и ожидаемые ответы (как мы хотим решать).

Компромисс в обучении

Обучение всегда про компромисс: модель должна быть достаточно простой, чтобы не «запоминать», и достаточно гибкой, чтобы ловить закономерности.

Избегание самообмана

Если проверка похожа на обучение, можно получить самообман.

Данные – это не «факт», а запись наблюдения с ошибками

Следы наблюдения

Данные в ИБ – это следы наблюдения, а не сама реальность.

Ограничения инструмента

Инструмент всегда ограничен: он что-то не видит, что-то упрощает, что-то искажает.

Распределенные события

В безопасности это особенно заметно: события распределены по системам, контекст разорван, источники разные.

Учет ограничений

Мы не ищем «идеальные данные», мы учимся учитывать ограничения данных в постановке и выводах.

Инструмент записи

Любая запись появляется через инструмент: сенсор, логирование, человек, регламент.

Неизбежные проблемы

Поэтому в данных неизбежны: пропуски, шум, разные форматы, двусмысленность.

Инженерный вопрос

Правильный инженерный вопрос: каким ошибкам подвержены наши данные и как это влияет на решения модели.

Источники ошибок

Технические ошибки

Неполное логирование, задержки, падения сборщиков.

Процессные ошибки

Разные правила ввода, ручные поля, изменения регламентов.

Человеческие ошибки

Опечатки, субъективность, разные трактовки.

Разметка – это договорённость, а не истина

Зависимость от политики

Разметка в ИБ зависит от политики и контекста.

Поздняя метка

Метка может появиться позже, после расследования, отражая решение процесса.

Договорённость

Разметка – это договорённость, которую надо явно понимать и фиксировать.

Разные метки

Один и тот же случай может получить разные метки у разных команд.

Неполная разметка

Разметка может быть неполной, часть инцидентов не обнаружили или не зарегистрировали.

Инженерная цель

Сделать так, чтобы модель решала ту задачу, которая реально нужна.

Кто и как задаёт метку

Эксперт

Вручную по правилам и опыту.

Процесс

По итогам расследования/ тикета.

Система

По формальным условиям (флаг, статус, категория).

Обобщение – это способность работать на новых случаях

Обобщение

Модель распознаёт смысловые закономерности, а не частные детали.

Новые случаи

В ИБ «новые случаи» возникают постоянно: меняется фон, инфраструктура, поведение пользователей, сценарии атак.

Риск

Риск появляется, когда новые случаи похожи внешне, но по сути уже другие.

Предсказуемое поведение

Невозможно гарантировать «всегда правильно» – можно добиться предсказуемого поведения и понятных границ применимости.

Инженерная привычка

Инженерная привычка: всегда задавать вопрос «что изменилось по сравнению с примерами?»

Важность курса

Именно поэтому в курсе важны: ясная постановка задачи, аккуратная проверка и честные выводы.

Переобучение – это когда модель запоминает детали вместо смысла

Определение

Модель слишком хорошо подстраивается под прошлые примеры.

Результат

На знакомых примерах выглядит отлично, а на новых – резко хуже.

Симптом

"Всё красиво в отчёте", но в реальной системе пользы мало.

Главная идея

Нам нужно, чтобы модель учила сигнал, а не шум.

Проблема

Она начинает опираться на случайные детали, которые в жизни не повторяются.

Риск в ИБ

В ИБ риск выше, потому что фон меняется, и «детали» быстро перестают быть полезными.

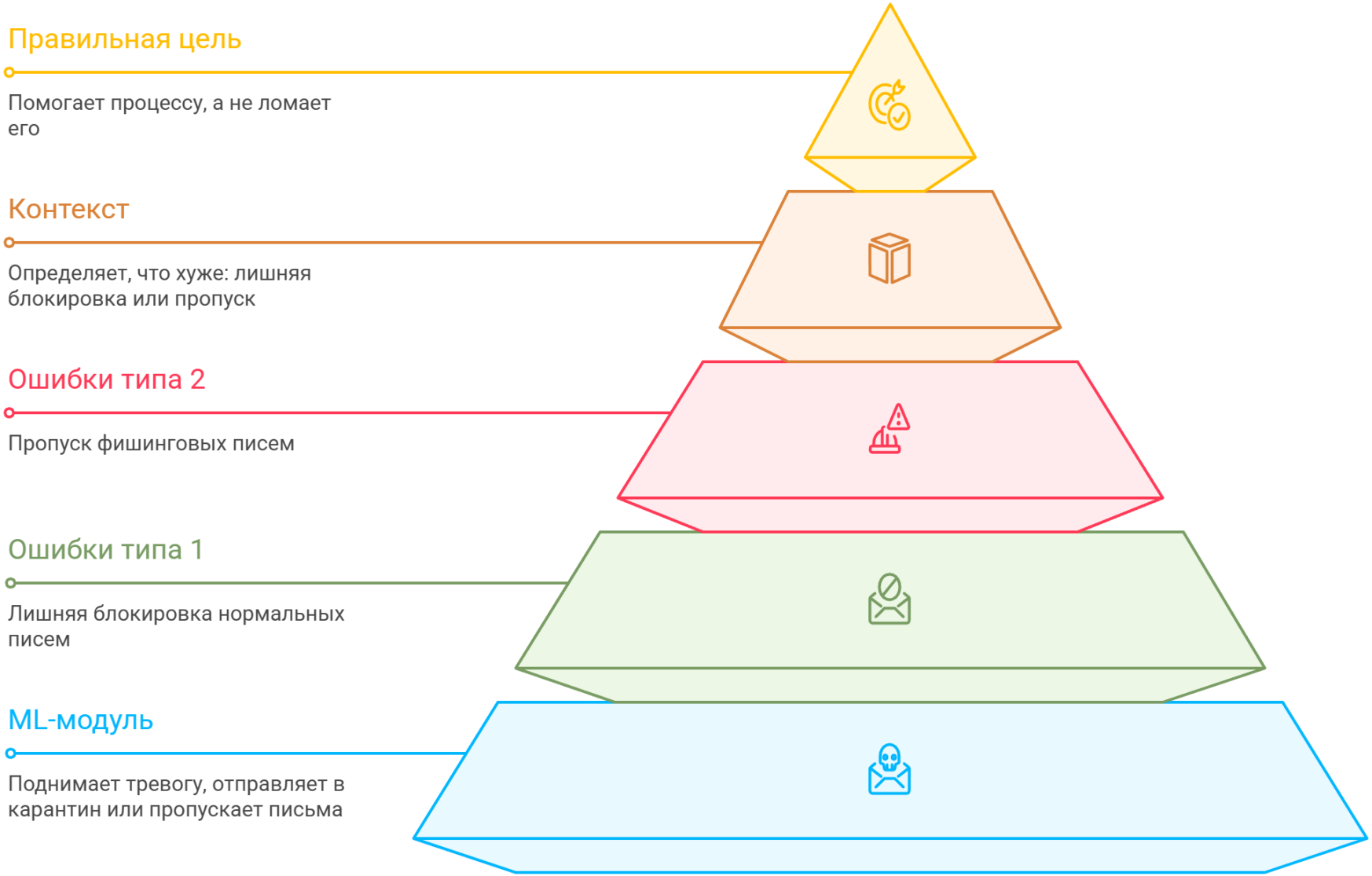
Лекарство

Держать правило проще, проверять на новых случаях и не верить «слишком идеальным» результатам.

Ложная тревога и пропуск инцидента – два разных вида ошибки

Характеристика	Ложная тревога	Пропуск
Определение	Система считает нормальный случай опасным	Система считает опасный случай нормальным
Последствия	Тратит ресурсы и доверие	Увеличивает ущерб
Выбор	Может быть дороже, если ресурсы ограничены	Может быть дороже, если ущерб значителен
Политика риска	Настройка системы для минимизации ложных тревог	Настройка системы для минимизации пропусков
Инженерная задача	Обеспечение полезности системы без ложных тревог	Обеспечение полезности системы без пропусков

Фишинг как пример: что хуже – лишняя блокировка или пропуск письма



Логи как пример: «нормально» меняется со временем

Что такое логи

Логи – это поток событий о работе систем: входы, запросы, ошибки, действия, сетевые обращения.

Поиск подозрительного

В логах мы часто хотим находить подозрительное: странные последовательности, всплески, нетипичные действия.

Проблема нормальности

Проблема: «нормально» не фиксировано – оно зависит от времени, нагрузки, обновлений, людей и регламентов.

Дрейф логов

Поэтому ML-решение в логах всегда живёт в мире дрейфа: фон меняется даже без атак.

Опасность дрейфа

Опасность: система начинает «кричать» на изменения нормальной работы или, наоборот, перестаёт замечать новое.

Инженерная мысль

Инженерная мысль: важно не только «найти аномалию», но и понимать, к чему мы сравниваем и почему это считается нормой.

Почему «хорошо на примерах» не гарантирует «хорошо в жизни»

Хорошо на примерах

Система справилась с тем, что уже было.

Разрыв между примерами и жизнью

Между этими двумя вещами почти всегда есть разрыв.

Понимать условия

Мы учимся понимать условия, при которых выводы верны.

Инженерная привычка

Заранее перечислить, что может пойти не так.

Хорошо в жизни

Система справилась с тем, что стало происходить.

Опасность не заметили

Опасность не в том, что разрыв существует, а в том, что его не заметили.

Правильный результат

Правильный результат – это решение, которое остаётся полезным.

Три причины разрыва

Меняются данные

Источники, фон, формат, поведение.

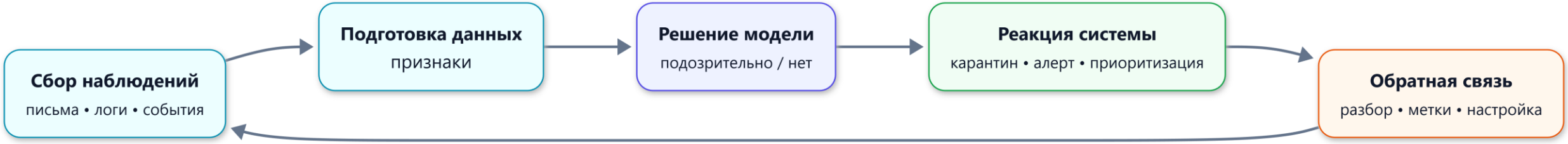
Меняется задача

Политика, критерии "плохо/нормально", приоритеты.

Меняется контур применения

Люди, процессы, реакция, дисциплина.

ML-решение в системе безопасности – это контур «сбор, решение, реакция, обратная связь»



Одно звено

ML – это одно звено в цепочке, а не вся безопасность.

Продуманная реакция

Самый частый провал – "сделали решение", но не продумали реакцию.

Обратная связь

Обратная связь нужна, чтобы система не деградировала при изменениях.

Полезность контура

Качество – это не только "решение", но и полезность контура в целом.

Управляемый контур

Мы будем смотреть на ML именно так: как на управляемый контур.

Безопасность ML в рамках курса означает управляемую надёжность модели в системе

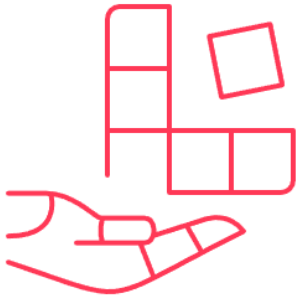
В нашем курсе «безопасность ML» – это ***управление рисками ошибок ML-модуля в реальной системе***

Надёжность

Модель ведёт себя предсказуемо на новых и меняющихся случаях.

Устойчивость

Решение не "сыпется", когда меняются условия и входные данные.



Контроль последствий

Как ошибки превращаются в действия системы и как их ограничить.

Проверяемость

Можно объяснить, что модель делает и почему ей можно доверять в оговорённых условиях.

Ответственность

Кто принимает решение, кто подтверждает, кто исправляет, как это фиксируется.

От базовых идей ML к управляемой надёжности решений

Вводная рамка
ошибки • риск • контур

→ **Данные и постановка**
наблюдения • разметка • цель

→ **Базовые модели**
простые правила решения

→ **Оценка и выводы**
проверяемость результата

→ **Надёжность в ИБ**
сдвиги • устойчивость • интерпретация

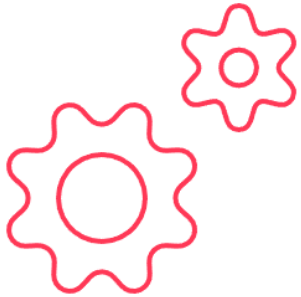
→ **Итоговые артефакты**
проект и отчёт

Язык и рамка

Начинаем с определения ошибок и рисков.

Решения на данных

Учимся принимать решения на основе данных и проверять себя.

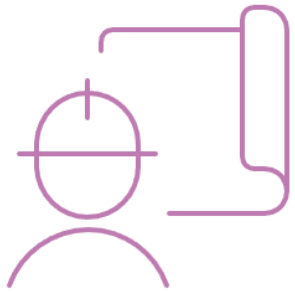


Базовые модели

Изучаем базовые модели как инструменты для понимания поведения.

Надежность

Изучаем, что ломает решения и как это диагностировать.



Применение

Финал – проект, где вы показываете управляемость и аргументацию.

Критичны доказательства проделанной работы, а не «красивые слова»

Проверяемые артефакты

Мы оцениваем проверяемые артефакты, а не "впечатление".

Защищаемые решения

В ИБ это критично: решения должны быть защищаемыми перед коллегами и заказчиком.

Инженерная культура

Это про инженерную культуру: показать ход мысли и ограничения.

Повторяемость и проверка

Артефакты нужны, чтобы результат можно было повторить, проверить и обсудить.

Вывод и обоснование

Поэтому каждая работа – это не "вывод", а вывод и обоснование.

Блок «что считается доказательством»

Постановка

Что именно вы решали и почему.

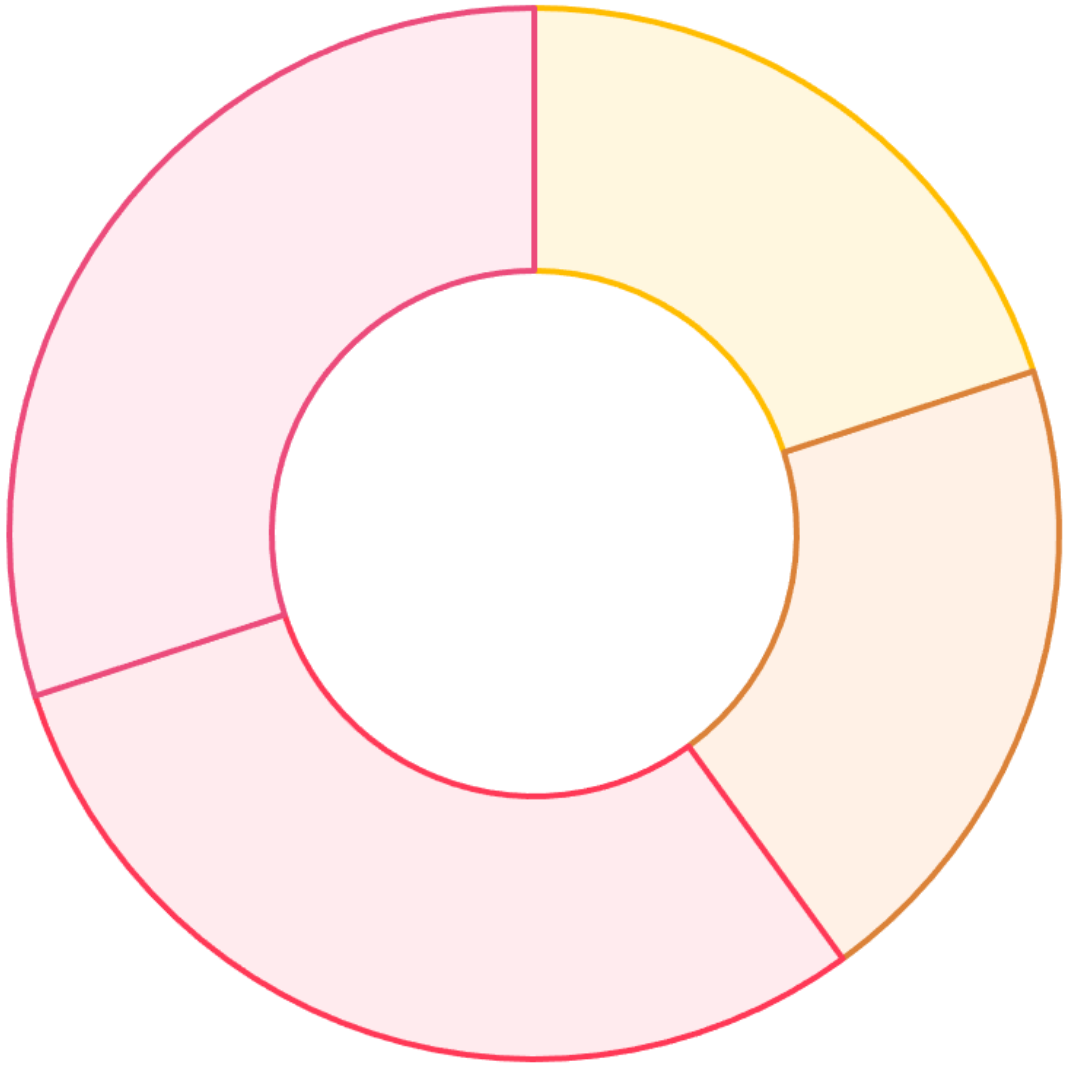
Данные

Что наблюдали и какие ограничения есть.

Выводы и риски

Что получилось и где может сломаться.

Оценивание на курсе



20% Контрольная работа

Проводится в конце 3 модуля

20% Экзамен

Проводится в конце 4 модуля

30% Домашние задания

Среднее из 3-4 заданий

30% Проектное задание

Сквозной проект по МО с элементами безопасности

Правила курса: академическая честность и принцип «не навреди»

Ваш вклад

Работа должна отражать ваш вклад и вашу логику.

Явные отметки

Заимствования допустимы, если они явно отмечены и не подменяют вашу работу.

Не выдавайте чужое

Нельзя выдавать чужое за своё: это не даёт реальные знания и делает оценку бессмысленной.

Принцип «не навреди»

В задачах ИБ дополнительно действует принцип «не навреди».

Безопасные демонстрации

Любые демонстрации должны быть безопасными: на учебных данных/песочнице, без реального ущерба.

Безопасная форма обсуждения

Если есть сомнение «может ли это быть использовано во вред» – выбираем безопасную форму обсуждения.

Пример плохой реализации

История в трёх шагах на *реальной компании*, внедрившей МО в существующие ИБ-решения

- Поставили «умный» детектор и тревог стало заметно больше.
- Часть тревог оказалась лишней, поэтому разбор стал рутиной и раздражением.
- В итоге тревоги перестали воспринимать всерьёз и реально важное сообщение затерялось.

Что пошло не так

- систему внедрили как «сигнал опасности», а не как **инструмент для работы**.
- реакцию сделали слишком жёсткой или слишком шумной.
- не договорились, **какие ошибки дороже** именно в этом процессе.
- не было понятного правила: что делать с тревогой и как быстро закрывать ложные.
- модель не объясняет, почему «кричит», а значит доверие падает быстрее.

Главный вывод

- В безопасности качество – это не только «как модель решает», но и **как люди и процесс переживают её ошибки**

Экспресс-проверка

Вопрос 1: Почему «ошибки модели» в ИБ – это ожидаемо, а не «провал разработки»?

Вопрос 2: Назовите два разных вида ошибки ML-решения и по одному типичному последствию для каждого.

Вопрос 3: Что в системе важнее, чем «умная модель», чтобы решение реально улучшало безопасность?

Сформулируйте ключевую мысль одним предложением: *«ML-модуль полезен, когда…»* – без слов «точность» и «процент».

Три опоры на весь курс

Часть системы

ML в безопасности – часть системы, а не отдельная магия. Важно смотреть на контур: «сбор, решение, реакция, обратная связь».

1

Управление риском

Ошибки неизбежны, поэтому главное – управление риском. Мы различаем виды ошибок и думаем о последствиях для людей и процесса.

2

Проверяемость и границы

Доверие появляется из проверяемости и честных границ применимости. Мы фиксируем, что проверили, чему можно доверять и что может измениться.

3

Самостоятельное изучение

Учебники

- Hastie, Tibshirani, Friedman – **The Elements of Statistical Learning** (2009) – база «на вырост».
- James, Witten, Hastie, Tibshirani – **An Introduction to Statistical Learning** (2021) – хороший вход и язык.
- Bishop – **Pattern Recognition and Machine Learning** (2006) – системное представление ML.

Риск и ответственность

- NIST – **AI Risk Management Framework 1.0** (2023) – рамка управления риском ИИ-решений.
- ACM – **Code of Ethics and Professional Conduct** (2018) – профессиональная ответственность.

Полезные практические ориентиры

- Google – **Rules of Machine Learning** – инженерные «анти-грабли».

Q&A и контакты

Группа по дисциплине:

https://t.me/+LLCsLRC2yp42Yjc6